

AWS Jam Challenge

Amazon ECR 资源策略修复

知识点总结 & 操作指南

涉及服务： Amazon ECR | AWS IAM | AWS CodeBuild

文档生成日期：2026 年 3 月 9 日

目录

1 题目背景

1.1 场景描述

在一个典型的 CI/CD 流水线中，**AWS CodeBuild** 负责构建 Docker 镜像并将其推送至 **Amazon ECR**（弹性容器注册表）。然而，由于 ECR 仓库配置了**资源策略（Resource-based Policy）**，其中存在一条 **Deny** 规则，导致 CodeBuild 的服务角色也被拦截，无法执行推送操作。

1.2 问题仓库

ECR 仓库名称: pyei-challenge-app

1.3 原始策略（有问题的配置）

```
1 {
2   "Version": "2012-10-17",
3   "Statement": [
4     {
5       "Sid": "DenyPutImage",
6       "Effect": "Deny",
7       "Principal": "*",
8       "Action": "ecr:PutImage"
9     }
10  ]
11 }
```

问题所在：该策略对 **Principal: "*" 全体主体拒绝 ecr:PutImage 操作**，没有任何例外，导致 CodeBuild 的服务角色（Service Role）也被拒绝推送镜像。

2 任务目标

修改 **DenyPutImage** 语句，使用 **条件键（Condition Key）** **aws:PrincipalArn** 排除 AWS CodeBuild 服务角色，使其不受 Deny 规则影响，从而恢复 CI/CD 流水线的正常推送能力。

验收标准：在 ECR 资源策略的 Deny 语句中，使用 `aws:PrincipalArn` 全局条件键排除 CodeBuild 服务角色 ARN。

3 操作步骤

3.1 第一步：获取 CodeBuild 服务角色 ARN

1. 登录 AWS 管理控制台
2. 导航至 IAM → Roles（角色）
3. 在搜索框输入 `codebuild` 进行筛选
4. 点击对应的 CodeBuild 服务角色
5. 复制其完整 ARN

ARN 格式示例：

```
arn:aws:iam::< 账号 ID>:role/codebuild-< 项目名 >-service-role
```

3.2 第二步：修改 ECR 资源策略

1. 进入 Amazon ECR 控制台
2. 在左侧导航栏选择 **Repositories**（仓库）
3. 点击仓库 `pyei-challenge-app`
4. 选择 **Permissions**（权限）标签页
5. 点击 **Edit policy JSON**
6. 将策略替换为修复后的版本（见第四节）
7. 点击 **Save**（保存）

3.3 第三步：验证修复结果

在 CI/CD 流水线中重新触发构建，或通过以下 AWS CLI 命令测试推送：

```
1 # 登录到 ECR
2 aws ecr get-login-password --region <region> | \
3     docker login --username AWS \
4         --password-stdin <account_id>.dkr.ecr.<region>.amazonaws.com
5
6 # 推送镜像
7 docker push <account_id>.dkr.ecr.<region>.amazonaws.com/pyei-
    challenge-app:latest
```

4 修复后的策略

4.1 完整策略 JSON

```
1 {
2     "Version": "2012-10-17",
3     "Statement": [
4         {
5             "Sid": "DenyPutImage",
6             "Effect": "Deny",
7             "Principal": "*",
8             "Action": "ecr:PutImage",
9             "Condition": {
10                 "ArnNotEquals": {
11                     "aws:PrincipalArn":
12                         "arn:aws:iam::123456789012:role/codebuild-xxx-service-
13                         role"
14                 }
15             }
16         ]
17     }
```

注意：请将 `arn:aws:iam::123456789012:role/codebuild-xxx-service-role` 替换为你在第一步中找到的真实 CodeBuild 服务角色 ARN。

5 核心知识点

5.1 IAM Policy 评估逻辑

AWS IAM 在评估权限时遵循以下优先级规则：

优先级	规则	结果
1	显式 Deny（无条件）	拒绝
2	显式 Deny（条件不满足时跳过）	取决于条件
3	显式 Allow	允许
4	隐式 Deny（无匹配语句）	拒绝

5.2 全局条件键 `aws:PrincipalArn`

`aws:PrincipalArn` 是一个 IAM 全局条件键（Global Condition Key），用于匹配发出请求的 IAM 主体（Principal）的 ARN。

条件运算符	含义	适用场景
<code>ArnEquals</code>	ARN 完全匹配	精确排除某个角色
<code>ArnNotEquals</code>	ARN 不匹配时为真	排除特定角色
<code>ArnLike</code>	ARN 支持通配符匹配	排除一类角色
<code>ArnNotLike</code>	ARN 不匹配通配符时为真	排除一类角色

5.3 Deny + ArnNotEquals 的组合逻辑

这是本题的核心逻辑，可用以下表格理解：

请求者	<code>ArnNotEquals</code> 结果	Condition 满足？	Deny 生效？
CodeBuild 角色	false	否	否（允许）
其他 IAM 主体	true	是	是（拒绝）

理解要点：条件（Condition）是 Deny 语句的触发门槛。只有当条件为 `true` 时，Deny 才生效。使用 `ArnNotEquals` 意味着：“除了指定的 ARN 以外的所有人，才触发拒绝”。

5.4 ECR 资源策略 vs IAM 身份策略

属性	ECR 资源策略	IAM 身份策略
附加对象	ECR 仓库（资源）	IAM 用户/角色/组
控制方向	谁可以访问此资源	此主体可访问哪些资源
跨账号访问	支持	需配合资源策略
Principal 字段	必须指定	不需要（隐式为附加主体）

5.5 Amazon ECR 常用操作权限

权限	用途
ecr:PutImage	创建或更新镜像 manifest 与 tag
ecr:GetDownloadUrlForLayer	拉取镜像层
ecr:BatchGetImage	批量获取镜像
ecr:GetAuthorizationToken	获取认证 Token（需 IAM 策略）
ecr:InitiateLayerUpload	初始化镜像层上传
ecr:UploadLayerPart	上传镜像层分片
ecr:CompleteLayerUpload	完成镜像层上传

6 架构图解

6.1 CI/CD 流水线与 ECR 交互流程

```

开发者提交代码
|
v
[AWS CodePipeline]
|
v
[AWS CodeBuild] <-- 使用 Service Role ARN
|
| docker push
v
[Amazon ECR]
pyei-challenge-app
|

```

| ECR 资源策略检查

v

DenyPutImage 语句

Condition: ArnNotEquals

CodeBuild Role ARN → 条件为false

→ Deny 不生效 → 允许推送

7 常见错误与排查

Q1. 使用了错误的条件键

错误：使用 `aws:PrincipalType` 或 `aws:userid`

正确：使用 `aws:PrincipalArn`，这是按角色 ARN 做精确匹配时最直接、最清晰的全局条件键。

Q2. ARN 填写不完整

错误：只填写角色名 `codebuild-role`

正确：必须填写完整 ARN，如 `arn:aws:iam::123456789:role/codebuild-role`

Q3. 条件运算符选择错误

错误：使用 `ArnEquals`（这会导致只有 CodeBuild 被拒绝）

正确：使用 `ArnNotEquals`（排除 CodeBuild，其余全部拒绝）

Q4. 忘记保存策略

修改完 JSON 后，必须点击 **Save** 按钮，否则修改不会生效。

8 总结

核心要点回顾：

1. ECR 资源策略的 Deny 语句可以通过 **Condition** 添加例外
2. 使用全局条件键 `aws:PrincipalArn` 匹配请求者的 ARN
3. `ArnNotEquals` + Deny 组合 = “除了指定 ARN 以外，全部拒绝”
4. 修复 CI/CD 流水线权限问题时，**最小权限原则**是首选方案
5. 排查 ECR 推送失败时，需同时检查 **ECR 资源策略**和 **IAM 身份策略**

AWS Jam Challenge 知识点总结文档
基于 Amazon ECR 资源策略排错场景